

WACRM - Vertical Clinica

Revision cerrada el 9 de septiembre de 2026 | Supabase produccion

Revision del codigo agregado para clinicas, con correcciones en IA, agenda, aislamiento de expedientes, archivos privados, recordatorios, concurrencia y dependencias.

17

hallazgos corregidos

1,813

pruebas aprobadas

0

vulnerabilidades npm

Estado de la entrega

La migracion 129 se aplico en una transaccion en Supabase produccion. El preflight encontro 0 solapamientos, 0 visitas duplicadas y no elimino datos clinicos.

Limite operativo consciente

La IA confirma o cancela una cita existente. Las nuevas citas y los reagendamientos pasan a recepcion hasta implementar una herramienta clinica nativa.

RESULTADO EJECUTIVO

Que cambio y por que importa

La version original no era segura para operar expedientes clinicos ni suficientemente confiable para afirmar cambios de agenda por chat. Los controles nuevos llevan la verdad de la cita a PostgreSQL, cierran accesos laterales y evitan que fallos comunes de IA terminen en silencio.

Garantias actuales de atencion automatica

- Una confirmacion o cancelacion se guarda antes de enviar el texto de exito.
- Proveedor caido, clave invalida, limite agotado, contexto fallido o respuesta vacia activan un mensaje fijo y handoff.
- Los handoffs tecnicos se recuperan automaticamente si ningun humano intervino; el contador de respuestas se reinicia.
- Si falla la metadata de empresa, se conserva el prompt medico estricto: no diagnosticar, recetar ni interpretar resultados.
- Una clinica no usa el agendamiento generico de Google Calendar, evitando eventos sin cita clinica.

Defensa de datos

- RLS separa empresas y limita a doctores con restrict_to_own.
- Triggers verifican empresa, paciente y relaciones aun cuando un job use service role.
- Storage privado exige metadata autorizada y URLs firmadas por 120 segundos.
- Viewer no puede subir ni borrar documentos clinicos.

Dependencias externas

Si WhatsApp/Meta tambien falla, el mensaje fijo puede no salir. El handoff queda registrado, pero la disponibilidad fuerte requiere una cola de salida persistente.

HALLAZGOS 1 DE 2

Riesgos criticos y altos corregidos

ID	Prioridad	Problema	Correccion
C01	CRITICA	La IA enviaba una confirmacion antes de guardarla.	Persistencia antes del mensaje; ante fallo, texto seguro y entrega a recepcion.
C02	CRITICA	Un doctor restringido podia ver pacientes o archivos de otros doctores.	RLS por paciente, visita, archivo y revision con pruebas reales como authenticated.
C03	CRITICA	Storage permitia lectura por ruta de empresa y subidas a viewer.	Storage exige metadata autorizada; solo owner/admin/agent suben o eliminan.
C04	ALTA	Dos solicitudes simultaneas podian reservar al mismo doctor.	Exclusion GiST en PostgreSQL; conflicto concurrente devuelve 409.
C05	ALTA	El cron marcaba recordatorios antes de enviarlos y podia perderlos.	Reclamos atomicos de 15 minutos; sello posterior al envio y reintento seguro.
C06	ALTA	Proveedor, limites, contexto o respuesta vacia podian dejar el chat en silencio.	Respuesta fija sin modelo, handoff transitorio, alerta y recuperacion automatica.
C07	ALTA	Google Calendar podia registrar un evento sin crear la cita clinica.	Agendamiento generico deshabilitado para clinicas hasta disponer de herramienta nativa.
C08	ALTA	Una lectura fallida del calendario se interpretaba como disponibilidad.	La validacion falla cerrada con 503 y nunca ofrece un slot no comprobado.
C09	ALTA	Cuentas hotel/generic podian invocar APIs clinicas directamente.	Todas las rutas exigen rol y vertical clinica antes de acceder a datos.

HALLAZGOS 2 DE 2

Integridad, validacion y rendimiento

ID	Prioridad	Problema	Correccion
C10	ALTA	FKs de auditoria y archivos podian mezclar empresas en caminos privilegiados.	Triggers tenant-guard revalidan empresa, paciente y relaciones aun con service role.
C11	MEDIA	Un horario invalido podia borrar toda la disponibilidad del doctor.	RPC transaccional; el horario anterior permanece si la sustitucion falla.
C12	MEDIA	Ediciones concurrentes podian sobrescribir citas, agenda o visitas.	Control optimista por updated_at y 409 para escrituras obsoletas.
C13	MEDIA	Fechas, UUID, montos, archivos y rangos sin limites causaban errores o abuso.	Validacion de calendario, UUID, 5-1440 min, 15 MB, MIME y slots hasta 62 dias.
C14	MEDIA	Errores de Supabase aparecian como ceros, vacios o doctor disponible.	Las consultas criticas propagan error y evitan datos falsos.
C15	RENDIMIENTO	Slots y agregados podian crecer sin control.	Maximo de 2,000 slots y agregados filtrados por pacientes candidatos.
C16	MEDIA	Reintentos podian crear dos visitas para una sola cita.	Indice unico parcial y respuesta 409 legible.
C17	CRITICA	Dependencias con RCE critica y avisos altos/moderados.	Next 16.3.4 y dependencias corregidas; npm audit final: 0 vulnerabilidades.

ESCALA

Condiciones para albergar 100 empresas

La ultima medicion documentada mostro 3 empresas, 6,844 mensajes y 46.57 MB de base de datos sobre Supabase Free/Nano. Esa fotografia no demuestra capacidad para 100 empresas. La RAM del VPS y la RAM de Supabase son recursos separados.

Limites que deben medirse

- El cron revisa hasta 200 cuentas y envia hasta 150 recordatorios cada 5 minutos. Es suficiente para 100 cuentas moderadas, pero una rafaga necesita cola justa por empresa.
- El panel carga visitas y citas en memoria y limita mensajes del periodo a 5,000. Los KPI deben migrar a agregados SQL.
- La lista de citas limita 1,000 filas y busca pacientes en memoria. Requiere paginacion y busqueda indexada.
- El debounce reside en un solo proceso. Dos replicas necesitan bloqueo distribuido por conversacion.
- API, webhooks, IA, archivos y cron comparten proceso. Separar workers protege la atencion HTTP de latencias del modelo.

Prueba de carga antes de prometer el objetivo

Escalones de 10, 25, 50 y 100 empresas; 30 a 60 minutos por nivel; rafagas de 5 a 10 veces el promedio; reinicio de worker durante la carga. Medir webhook p95, API p95, edad de cola, errores externos, duplicados, CPU, RAM, conexiones y crecimiento de BD.

Criterio comercial

No afirmar capacidad de 100 empresas hasta completar la prueba con datos sinteticos y proveedores simulados, sin enviar mensajes a pacientes reales.

HOJA DE RUTA

Trabajo pendiente priorizado

Nivel	Iniciativa	Resultado esperado
P0	Cola persistente de IA y salida	Trabajo durable por conversacion, reintentos, idempotencia y dead-letter para sobrevivir reinicios y caidas externas.
P0	Backups y restauracion	Activar copias de BD/archivos y demostrar una restauracion antes de almacenar expedientes reales.
P1	Herramienta clinica nativa para IA	Consultar slots, reservar y reagendar mediante operaciones deterministas y autorizadas.
P1	Transacciones clinicas completas	Unir visita, cierre de cita e historiales auxiliares en RPCs atomicos.
P1	Metricas SQL y paginacion	Eliminar limites silenciosos de filas y filtros en memoria antes de historiales grandes.
P1	Observabilidad por empresa	Alertar chats sin respuesta, handoffs sin dueño, cron fallido, claims vencidos y latencia p95/p99.
P2	Retencion y minimo privilegio	Definir plazos, registrar accesos y confirmar si recepcion debe ver notas medicas.

Riesgos residuales concretos

- Algunos historiales auxiliares y el cierre cita-visita siguen siendo operaciones separadas; una caida intermedia puede dejar auditoria incompleta.
- Recepcion puede leer notas medicas por el modelo de roles actual. La politica debe validarse contra la operacion y la ley aplicable.
- La disponibilidad total depende de Supabase, Meta/WhatsApp, el proveedor de IA, DNS y red.
- Supabase Free sin backups programados no es una base apropiada para expedientes clinicos de produccion.

Orden recomendado

1. Cola persistente + idempotencia
 2. Backups y restauracion ensayada
 3. Herramienta clinica nativa de agenda
 4. Metricas SQL + paginacion
 5. Prueba de carga 10 -> 25 -> 50 -> 100

DESPLIEGUE Y EVIDENCIA

Validacion completada

- Supabase produccion: 1 cuenta clinica, 0 citas y 0 visitas al preflight.
- 0 horarios activos superpuestos y 0 citas con visitas duplicadas.
- Migracion 129 aplicada en una transaccion y registrada como 20260909193000 / clinic_reliability_and_security.
- 179 archivos de prueba y 1,813 pruebas aprobadas con Vitest 4.1.11.
- TypeScript y ESLint sin errores.
- Compilacion de produccion correcta con Next.js 16.3.4 y 121 paginas generadas.
- npm audit: 0 vulnerabilidades en 871 paquetes.
- Pruebas PostgreSQL reales para RLS, triggers, claims y reemplazo atomico de agenda.

Versiones de seguridad instaladas

```
next 16.3.4
sharp 0.35.4
nodemailer 9.1.1
js-yaml 4.3.2
hono 4.13.7
vitest 4.1.11
```

Comprobacion operativa de 24 horas

- Confirmar que clinic-reminders-sweep corre cada 5 minutos y registra heartbeat.
- Vigilar clinic reminders, ai auto-reply, handoffs transitorios y campos last_error.
- Probar dos reservas concurrentes del mismo doctor/hora: un exito y un 409.
- Probar un doctor restringido contra paciente, visita, revision y archivo ajenos.

Resultado

El kit de Clinica queda sustancialmente mas seguro y resiliente. La siguiente inversion prioritaria es durabilidad de la atencion mediante una cola persistente.